
一、什么是 **Refresh Token**?

Refresh Token（刷新令牌）是配合 Access Token（访问令牌）使用的一种认证机制，用于在 Access Token 过期后，无需用户重新登录，通过 Refresh Token 换取新的 Access Token，从而提升用户体验和安全性。

二、为什么需要 **Refresh Token**?

1. Access Token 通常有效期很短（几分钟到几十分钟）

- 防止被盗后长期使用。

2. 用户不可能频繁输入密码

- 为了避免用户频繁登录，我们使用 Refresh Token 来自动续签新的 Access Token。
-

三、**Refresh Token** 的工作流程

1. 用户登录

- 用户提交用户名密码。
- 服务器验证后生成一对 Token：
 - **Access Token**：用于访问资源，通常较短时效。
 - **Refresh Token**：用于刷新 Access Token，通常较长时效。

2. 访问受保护资源

- 客户端每次请求 API 时携带 Access Token。

3. Access Token 过期

- 客户端用 Refresh Token 向服务器请求新的 Access Token。

4. 服务器验证 **Refresh Token**

- 验证通过后生成新的 Access Token（也可能生成新的 Refresh Token）。

5. 刷新成功或失败

- 成功：继续访问资源。
 - 失败（如 Refresh Token 过期或被撤销）：客户端必须重新登录。
-

四、Refresh Token 的存储位置（客户端）

1. Web 应用：

- Access Token：存在内存中或短期 cookie。
- Refresh Token：建议存在 HttpOnly、Secure 的 cookie 中。

2. 移动端或桌面应用：

- 可以保存在加密的本地存储或系统密钥链中。
-

五、Refresh Token 的安全设计要点

1. 设置合理的过期时间（如 7 天、30 天）

2. 绑定用户设备 / IP / User-Agent

3. 可撤销机制

- 如用户登出、密码更改、异常登录等操作撤销已有 Refresh Token

4. 限制使用次数或频率

- 防止被攻击者暴力尝试使用。
-

六、例子（基于 JWT）

用户登录后返回：

json

复制编辑

```
{
  "access_token": "eyJhbGciOiJIUzI1NiIs... ",
  "refresh_token": "def50200b2c9ef4d4f..."
}
```

刷新接口：

http

复制编辑

POST /auth/refresh

Content-Type: application/json

```
{
  "refresh_token": "def50200b2c9ef4d4f..."
}
```

七、总结

项目	ACCESS TOKEN	REFRESH TOKEN
用途	访问资源接口	换取新的 Access Token
时效	短（几分钟）	长（几天或更久）
位置	内存、Header	Cookie、本地存储
风险	被盗可直接访问资源	被盗可长期获取 Token（更危险）